Introduction

The purpose of this document is to evaluate potential security weaknesses and implement security controls within the mobile app's infrastructure.

Scope of Work

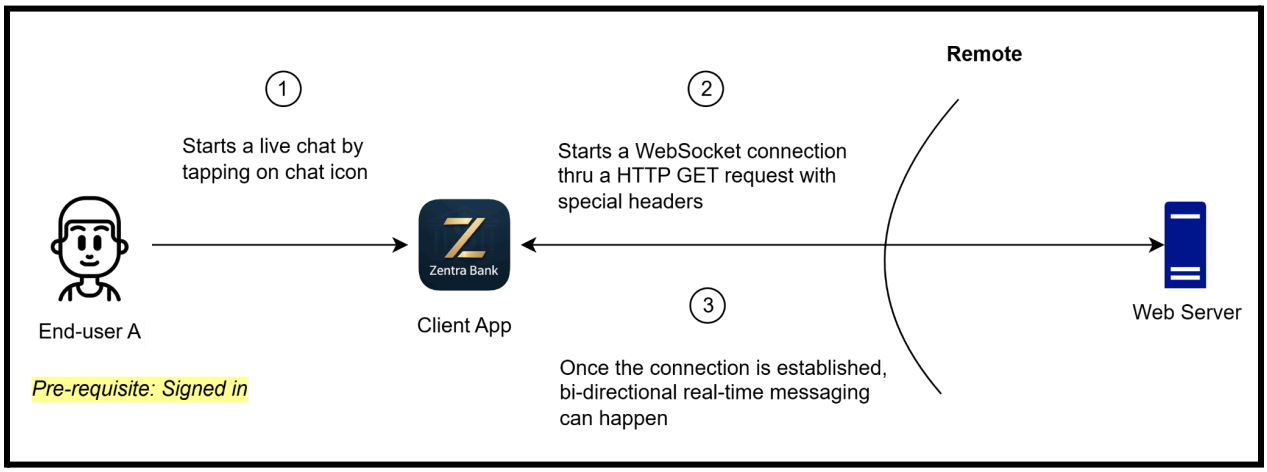
This exercise focuses on 1 user story within the Zentra Bank mobile app:

1. As a user, I want to **send real-time messages through a web socket connection** to customer support so that I can get immediate help with my issues.

Out of Scope

This exercise strictly focuses on the mobile application and its functionalities. Any components outside the mobile app, which includes but not limited to REST APIs, server infrastructure, remote database, and external services, are not within the scope.

User story 8



The data flow for this user story is as follows:

"As a user, I want to send real-time messages through a web socket connection to customer support so that I can get immediate help with my issues."

1. The **End-user** opens the chat screen in the Client App (CA).

2. The **Client App (CA)** initiates a connection to the `/ws` endpoint of the Web Server (WS) using the OkHttp client library. It sends an initial HTTP request with an *Upgrade* header requesting a WebSocket.

Request

Pretty Raw Hex

```
GET /ws?role=customer HTTP/1.1
origin: http://10.0.2.2:8000
Upgrade: websocket
Connection: Upgrade
Sec-WebSocket-Key: l+OailxfNgQ8OIeYvkrtfw==
Sec-WebSocket-Version: 13
Host: 10.0.2.2:8000
Accept-Encoding: gzip, deflate, br
User-Agent: okhttp/4.9.2
```

3. The **Web Server (WS)** receives the request, handles the upgrade, and establishes the WebSocket connection.

Pretty Raw Hex


```
1 {
    "type":"ready",
    "role":"customer",
    "conversationId":"1ee4b286-5540-46a1-a0ea-8c4487a8986e"
  }
```


4. The WebSocket session is now active, enabling **real-time, bi-directional messaging** between the end-user and customer support.